

Secrets and credentials

#	Check	Yes / No / N/A	Evidence
1	.env is gitignored and is not in the repository	Yes	.gitignore includes .env; confirmed via git status/git add . output, which never listed .env as tracked.
2	A .env.example with placeholder values only is committed	Yes	Created with DATABASE_URL=your_connection_string_here — no real value.
3	No connection string, key, token or password is hardcoded in source, comments or commented-out code	Yes	app.js only reads process.env.DATABASE_URL; the real string was never pasted into any .js file, only .env.
4	Git history is clean: I searched git log -p for password, secret, api key and postgres://	Yes	No credentials were found in the searched Git history.
5	Any credential that was ever committed has been rotated	N/A	N/A — No credentials were found to have been committed, so rotation was not necessary.
6	Production credentials live only in my hosting provider's	Yes	DATABASE_URL was set directly in Render's Environment tab, not in any repo file.

#	Check	Yes / No / N/A	Evidence
	environment settings		

GitHub Actions

If your project has no workflows, mark every row N/A and say so once.

#	Check	Yes / No / N/A	Evidence
7	No secret value is written literally in any workflow YAML file	N/A	No GitHub Actions workflow YAML files exist in the project.
8	Secrets are stored in repository Actions secrets and read with <code>\${{ secrets.NAME }}</code>	N/A	No GitHub Actions workflows or Actions secrets are used.
9	No workflow step echoes, dumps or debug-prints a secret, and I opened a recent run's log to confirm	N/A	No workflows or workflow runs exist to inspect.
10	Uploaded build artifacts contain no .env, key file or generated config	N/A	No GitHub Actions workflows upload build artifacts.
11	Third-party actions are pinned to a commit SHA, not a moveable tag	N/A	No workflows use third-party actions.

#	Check	Yes / No / N/A	Evidence
12	Secret scanning and push protection are enabled on the repository	N/A	No GitHub Actions workflows are configured; GitHub's separate secret-scanning settings are not part of this workflow check.

Database

#	Check	Yes / No / N/A	Evidence
13	Every query taking user input uses parameters, never string concatenation	Yes	Every query in app.js uses \$1/\$2/\$3 placeholders.
14	The database is not open to the whole internet, or is reachable only by the app	No	Neon databases are internet-reachable by default (password + SSL only, no IP allowlist configured).
15	The database user the app connects as has only the permissions it needs	Yes	Connects as neondb_owner — default owner-level account, not a scoped role.
16	Seed and sample data is invented, not real people's data	Yes	Test words only ("bahay," "hello," "carlos," etc.).
17	Debug, seed and reset routes are removed before going public	Yes	DELETE /api/history wipes the whole table, is live, and has zero access control.

Access control

#	Check	Yes / No / N/A	Evidence
18	The app has an access layer: Cloudflare Zero Trust, an app-level password, or a real login	No	Has a password gate
19	If Supabase or Firebase: Row Level Security or security rules are on, and I tested it signed out	N/A	Not using any of those
20	If Zero Trust: tjakoens@gmail.com is on the access policy. If an app password: the credentials are in my private workspace project/README.md	N/A	No Zero Trust or app-password access gate is configured. The application currently has no authentication.
21	The gate covers every route, including the ones that only change data	Yes	No gate at all — DELETE /api/history is fully exposed.
22	The credentials for the gate are environment variables, not in source	Yes	No access gate or gate credentials are configured.

Input and output

#	Check	Yes / No / N/A	Evidence
23	Input from the user is validated on the server, not only in the browser	Yes	POST /api/convert validates text and direction server-side before processing.
24	User-supplied text is escaped when rendered,	Yes	Rendered through React JSX, which escapes by default; no dangerouslySetInnerHTML anywhere.

#	Check	Yes / No / N/A	Evidence
	so it cannot inject markup or script		
25	Error responses do not expose stack traces, file paths or connection details	Yes	Catch blocks log details server-side only; client gets generic messages.
26	CORS is not a wildcard on routes that change data	Yes	app.use(cors()) allows all origins on every route, including DELETE.

Repository and privacy

#	Check	Yes / No / N/A	Evidence
27	No student number, personal email, phone number or home address in the repository or in commit messages	Yes	No such information was identified in the repository or commit messages.
28	No classmate's personal data in the repository	Yes	No data about other people anywhere in this project.
29	Dependencies come from official registries, and node_modules is gitignored	Yes	Standard npm packages; node_modules confirmed absent from commits repeatedly.
30	Images, fonts and other assets are mine, licensed, or credited	Yes	Fonts loaded via official Google Fonts CDN under open licenses.

#	Check	Yes / No / N/A	Evidence
31	Repository visibility is deliberate, and I checked it after my last push	Yes	Repository visibility was checked after the last push.

Anything I found and fixed

Write two or three sentences. What did this checklist catch that you did not already know about, and what did you change? If it caught nothing, say that. An honest "nothing, and here is what I checked" is worth more than an invented finding.